

Prepared by: Abdul Wahid
Document Type: Vulnerability Assessment Report
Category: Network & Vulnerability Scanning (Nmap + OpenVAS)

Executive Summary

This assessment evaluated a Metasploitable2 VM (192.168.100.148), scanned from the author's own Kali VM (192.168.100.140) in a private, isolated lab. Nmap was used for discovery and service enumeration, followed by two OpenVAS scans, one unauthenticated and one credentialed. Nmap found 30 open TCP ports. OpenVAS reported 64 findings at QoD ≥ 70%: 10 Critical, 11 High, 37 Medium, and 6 Low, with a top CVSS score of 10.0.

The most serious issues can be exploited remotely without credentials. These include backdoored services (vsftpd 2.3.4, UnrealIRCd, Ingreslock), remote code execution flaws (DistCC, Samba, Java RMI, Tomcat), default credentials (PostgreSQL, VNC, FTP), and passwordless rlogin and rsh. OpenVAS obtained a root shell (uid=0) from port 1524 with no login. The root cause is Ubuntu 8.04, which has been end of life since 2013 and cannot be secured by patching.

Both OpenVAS scans returned identical findings, so credentials added no visible results. Remediation should start by disabling the backdoored and legacy services, then changing default credentials, and finally rebuilding the system on a supported OS.

Contents

Preparation 4

Discovery and baseline (Nmap) 6

- Host discovery 6
- Full TCP port scan 7
- Service, version, and OS detection 8
- UDP check (top 100 ports) 8
- Quick vulnerability cross-check with NSE 9
- Review and save evidence 10

OpenVAS scan 1 (unauthenticated) 11

- Start GVM and check health 11
- Make sure the feeds are synced 13
- Performing Scan-1 15
- Running Scan-1 17
- Report Generated 18

OpenVAS scan 2 (credentialed) 19

- Creating a Second Task 21
- Running Scan-2 22
- Report Generated 23

Analysis 24

- Scan overview 24
- Nmap vs. OpenVAS 24
- Key findings by risk theme 25
- Authenticated vs. unauthenticated comparison 27
- Remediation priorities 27
- Limitations 28

Conclusion 29

Preparation

Your lab:

- Kali (scanner)： `192.168.100.140`
- Metasploitable2 (target): `192.168.100.148`

Snapshot both VMs

In VMware or VirtualBox, take a snapshot of each VM:

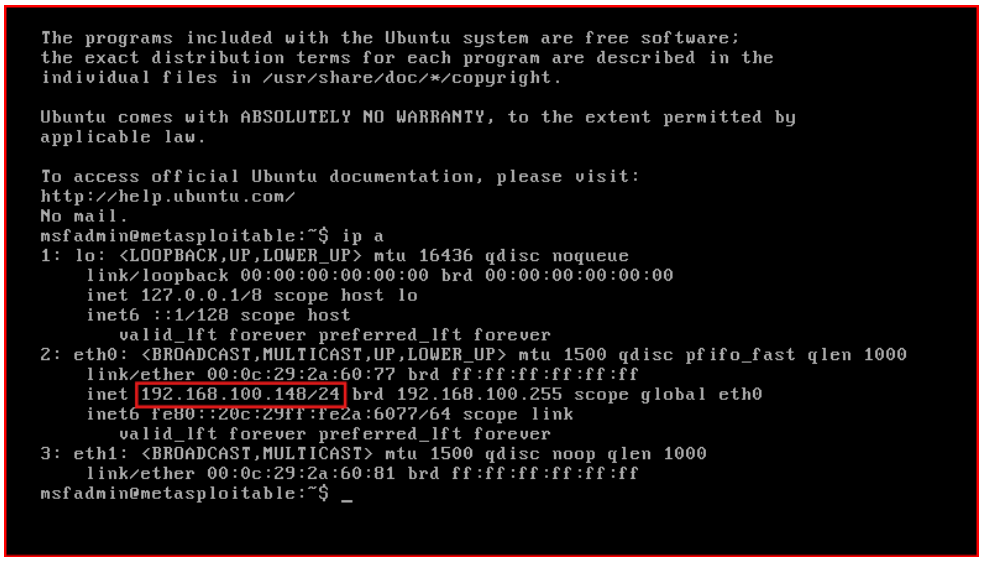
- Kali: Kali-Clean-Baseline
- Metasploitable2: MS2-Vulnerable-Baseline

Isolate the network

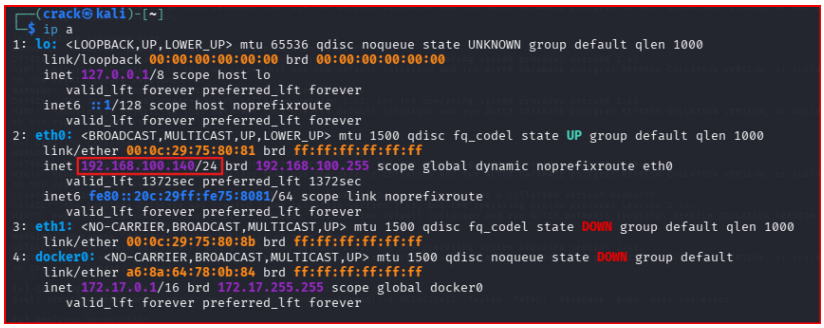
This assessment was performed in a private, isolated lab. The only target is the author's own Metasploitable2 VM (192.168.100.148), scanned from the author's own Kali VM (192.168.100.140). No other systems were tested.

Confirm both IPs

On Metasploitable2 (login msfadmin / msfadmin):

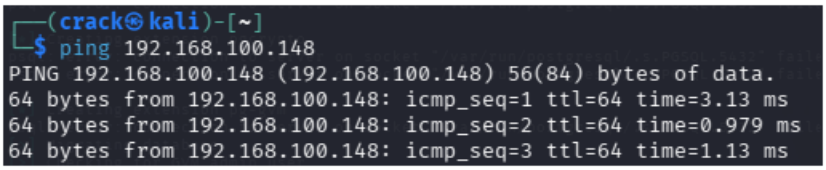


On Kali:



Test connectivity from Kali:

```
ping -c 3 192.168.100.148
```

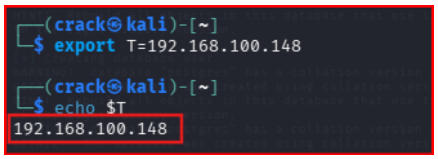


You should see 0% packet loss. If not, check that both VMs are on the same virtual network.

Set a variable on Kali so later commands are shorter:

```
export T=192.168.100.148
```

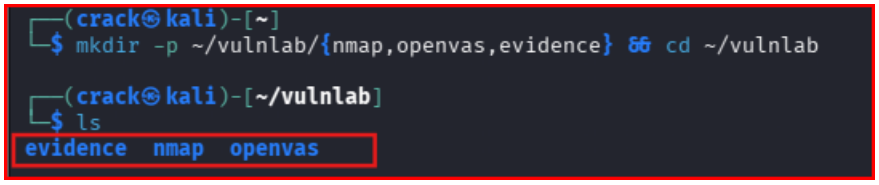
```
echo $T
```



Note that this variable lasts only for the current terminal. If you open a new terminal, run the export again.

Create the working folder

```
mkdir -p ~/vulnlab/{nmap,openvas,evidence} && cd ~/vulnlab
```



Discovery and baseline (Nmap)

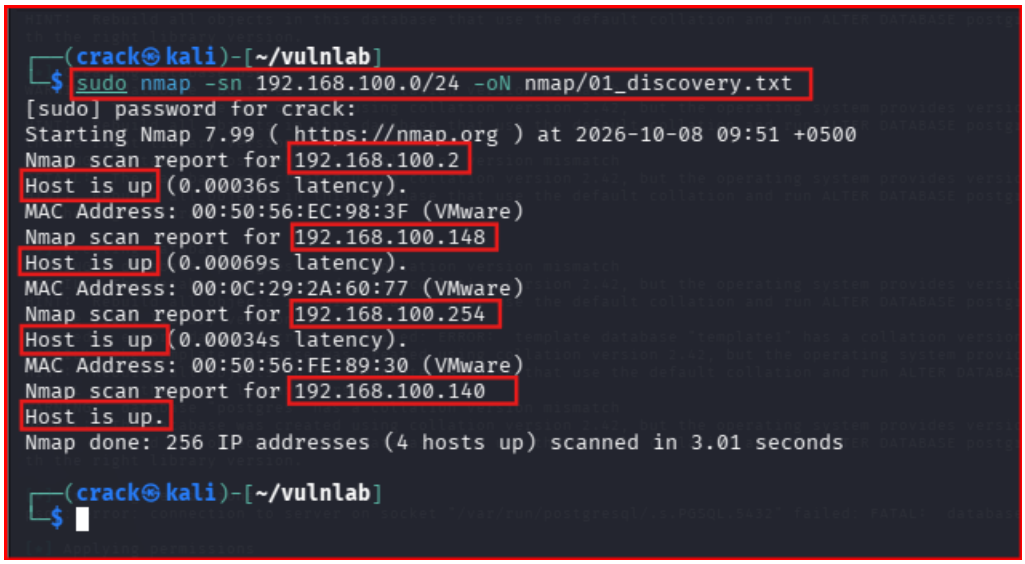
Lab: Kali 192.168.100.140 → Metasploitable2 192.168.100.148

Goal: build a baseline of the target's open ports, services, versions, and OS *before* OpenVAS runs, so you can compare tools and measure remediation later.

Host discovery

Confirm which hosts are alive on your lab subnet:

```
sudo nmap -sn 192.168.100.0/24 -oN nmap/01_discovery.txt
```



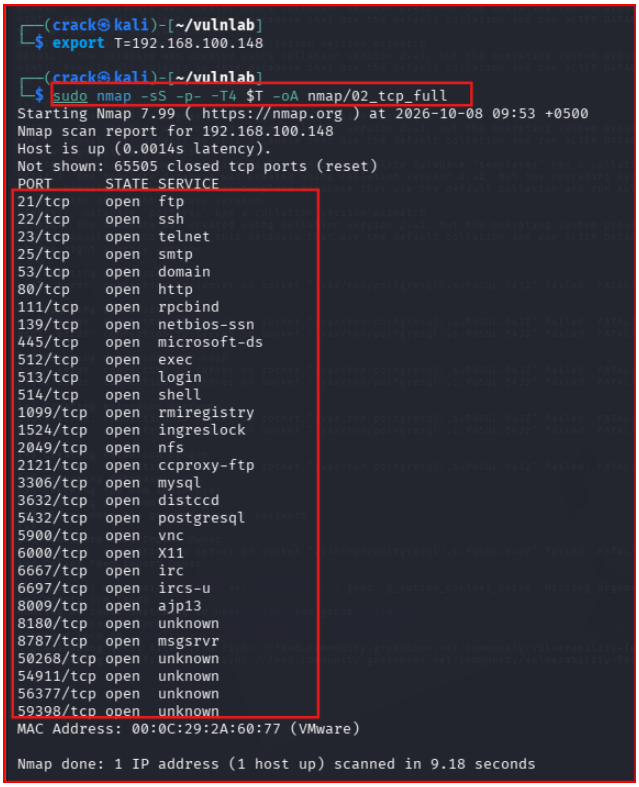
Expect: your Kali (.140), the target (.148), and possibly the gateway or DHCP server. Metasploitable2 should show "Host is up" with a VMware

---

Full TCP port scan

Scan all 65,535 ports with a SYN scan:

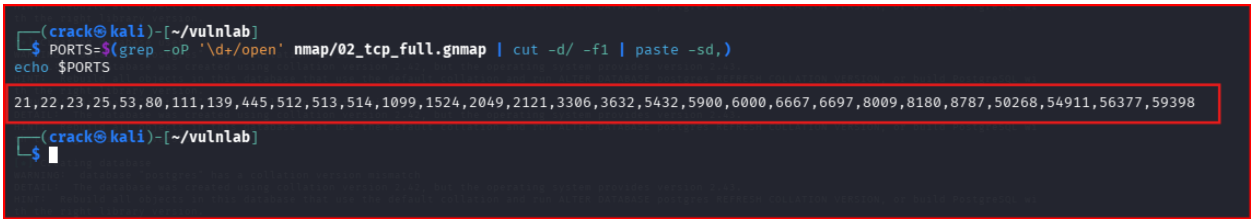
```
sudo nmap -sS -p- -T4 $T -oA nmap/02_tcp_full
```



Extract the open ports as a comma-separated list for the next step:

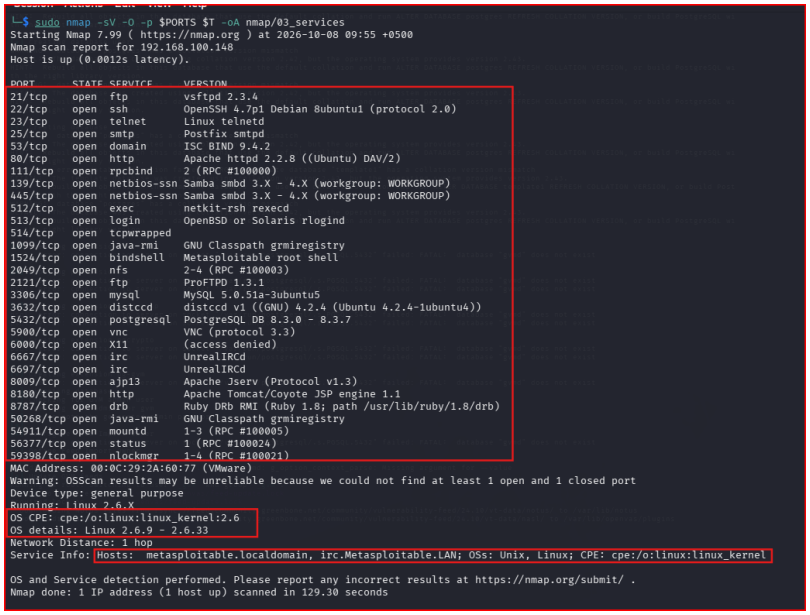
```
PORTS=$(grep -oP '\d+/open' nmap/02_tcp_full.gnmap | cut -d/ -f1 | paste -sd,)
```

```
echo $PORTS
```



Service, version, and OS detection

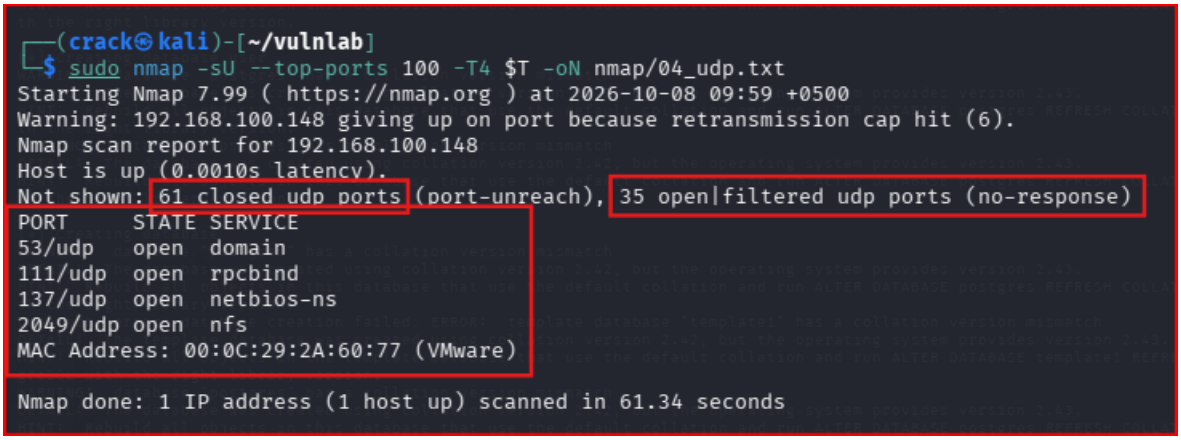
sudo nmap -sV -O -p $PORTS $T -oA nmap/03_services



- -sV identifies service names and versions (for example vsftpd 2.3.4, OpenSSH 4.7p1, Apache 2.2.8).
- -O guesses the OS (Linux 2.6.x for Metasploitable2).

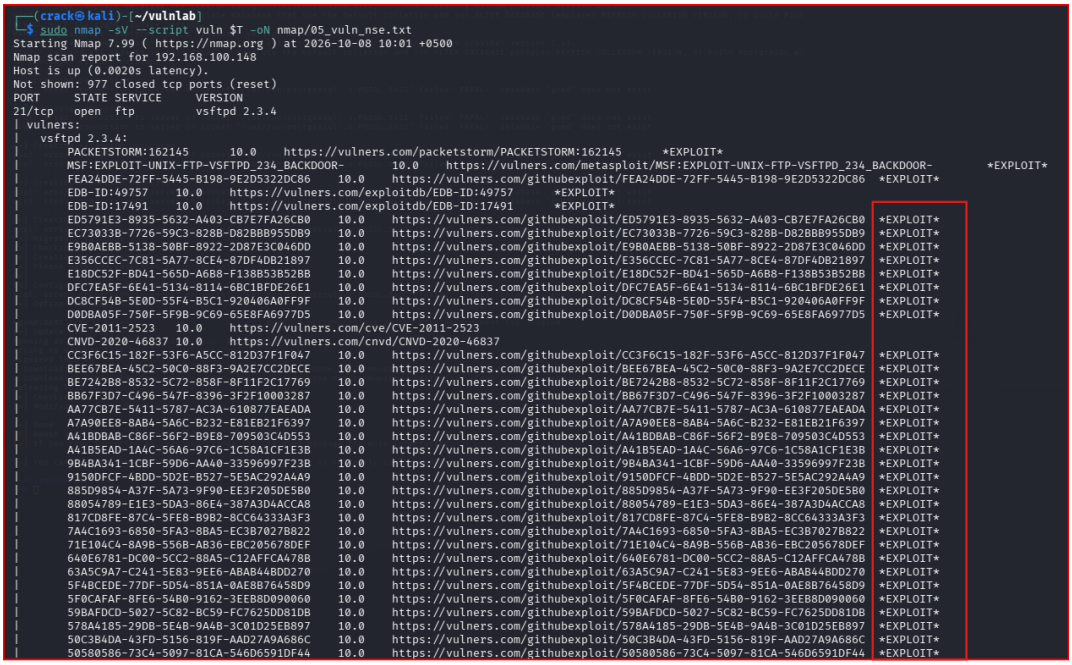
UDP check (top 100 ports)

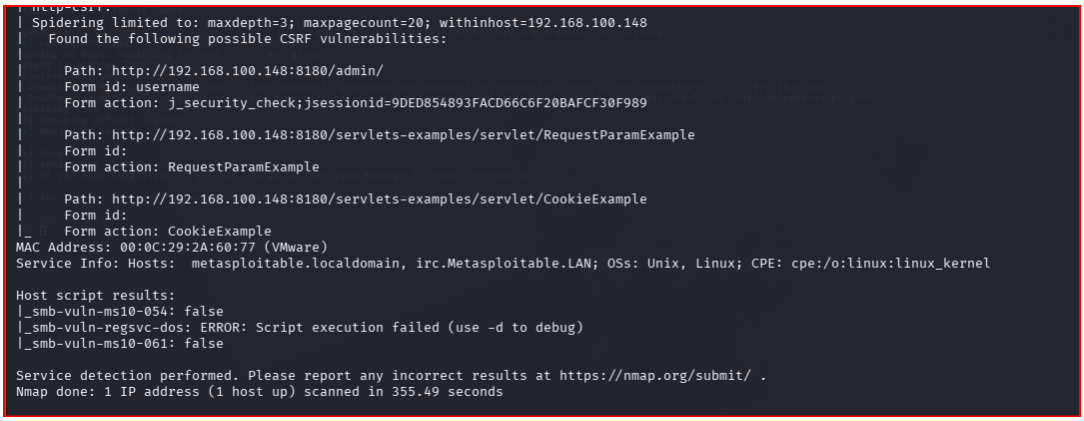
```
sudo nmap -sU --top-ports 100 -T4 $T -oN nmap/04_udp.txt
```



Quick vulnerability cross-check with NSE

sudo nmap -sV --script vuln $T -oN nmap/05_vuln_nse.txt





This can take 10 to 20 minutes. It runs detection scripts that flag known vulnerabilities and misconfigurations.

Expect: findings such as vsftpd backdoor detection, anonymous FTP, SMB or Samba issues, and weak SSL/TLS settings.

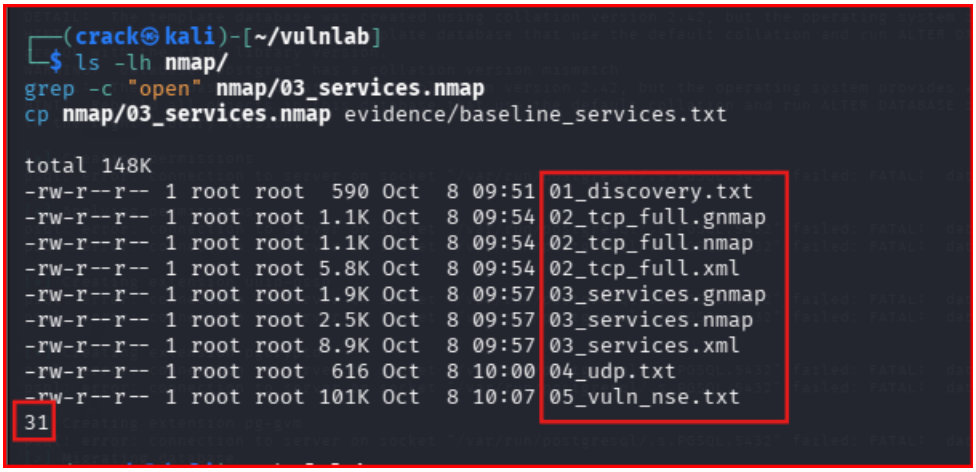
Note: the vuln category is detection-oriented, but some scripts probe services actively.

Review and save evidence

```
ls -lh nmap/

grep -c "open" nmap/03_services.nmap

cp nmap/03_services.nmap evidence/baseline_services.txt
```



OpenVAS scan 1 (unauthenticated)

Lab: Kali 192.168.100.140 → Metasploitable2 192.168.100.148

Goal: run a network-based, non-credentialed vulnerability scan. It sees the target the way an outside attacker would, and it is your reference point for the credentialed scan in Phase 3.

Upgrading dependencies

```
┌──(crack㉿kali)-[~]
└─$ sudo apt update && sudo apt upgrade -y
[sudo] password for crack:
Get:1 https://download.docker.com/linux/debian bullseye InRelease [43.0 kB]
Get:2 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Packages [21.6 MB]
Get:4 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [54.2 MB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Packages [104 kB]
Get:6 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [183 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Packages [170 kB]
Get:8 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [893 kB]
Fetched 77.3 MB in 59s (1,310 kB/s)
```

Start GVM and check health

Setup gvm

```
┌──(crack㉿kali)-[~]
└─$ sudo apt install gvm -y
The following packages were automatically installed and are no longer required:
  bluez-hcidump              libhdf5-310          libmupdf27.0       libpython3.13-dev             linux-bina
  firmware-marvell-prestera  libhdf5-hl-310       libntfs-3g89t64    libpython3.13-minimal         linux-imag
  libabsl20260107            libimath-3-1-29t64   libobjc-15-dev     libpython3.13-stdlib          linux-modu
  libbluray3                 libjim0.83           libopenjph0.27     libsimdutf33                  network-ma
  libconfig++11              libkmlbase1t64       libperl5.40        libvidstab1.1                 openssh-cl
  libconfig11                libkmldom1t64        libpoppler156      libx265-215                   perl-modul
  libgeos3.14.1              libkmlengine1t64     libpython3.13      linux-base-6.19.14+kali-amd64 python3-m
Use 'sudo apt autoremove' to remove them.

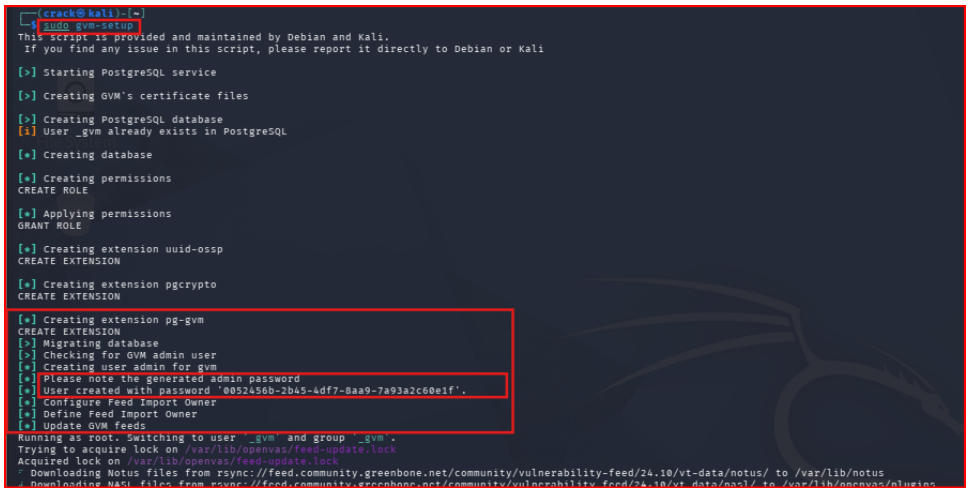
Installing:
  gvm

Installing dependencies:
  greenbone-security-assistant  gsad  gvm-tools

Summary:
  Upgrading: 0, Installing: 4, Removing: 0, Not Upgrading: 9
  Download size: 2,482 kB
  Space needed: 15.9 MB / 12.6 GB available

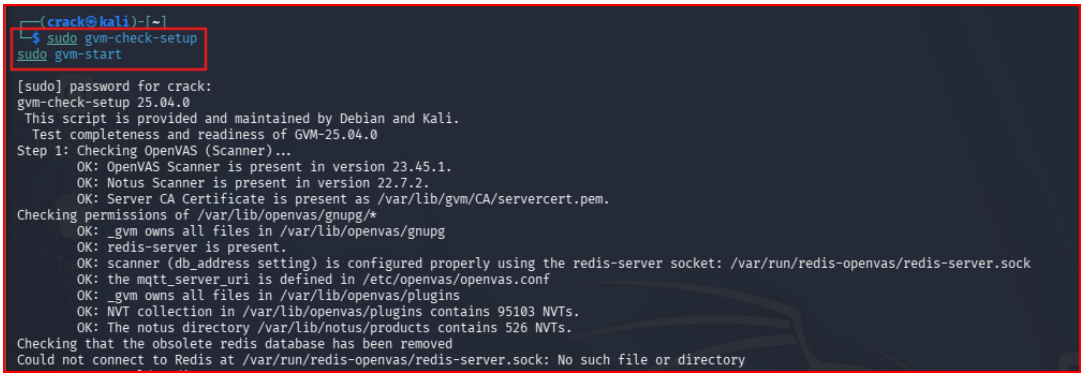
Get:2 http://kali.download/kali kali-rolling/main amd64 gsad amd64 24.16.0-1 [141 kB]
Get:3 http://kali.download/kali kali-rolling/main amd64 gvm all 25.04.3 [12.1 kB]
Get:4 http://kali.download/kali kali-rolling/main amd64 gvm-tools all 25.4.6-1 [153 kB]
Get:1 http://mirror.yer.az/kali kali-rolling/non-free amd64 greenbone-security-assistant all 26.17.0-0kali1
Fetched 2,482 kB in 6s (450 kB/s)
Selecting previously unselected package greenbone-security-assistant.
(Reading database… 500948 files and directories currently installed.)
Preparing to unpack …/greenbone-security-assistant_26.17.0-0kali1_all.deb…
```

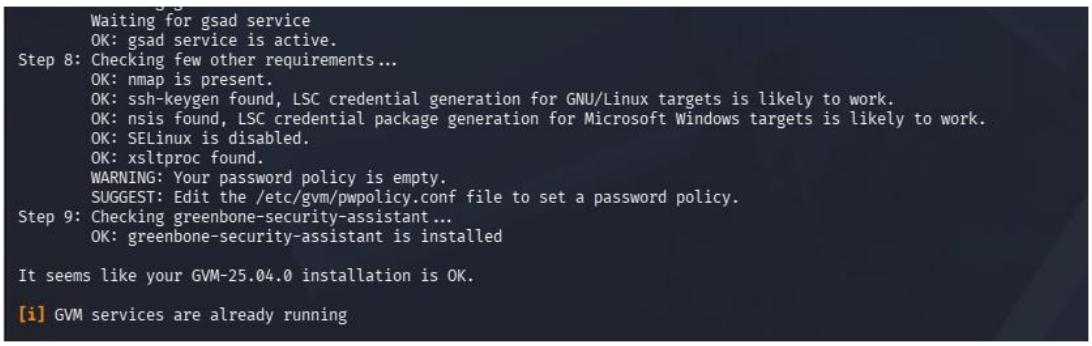
Setting up gvm



`sudo gvm-check-setup`

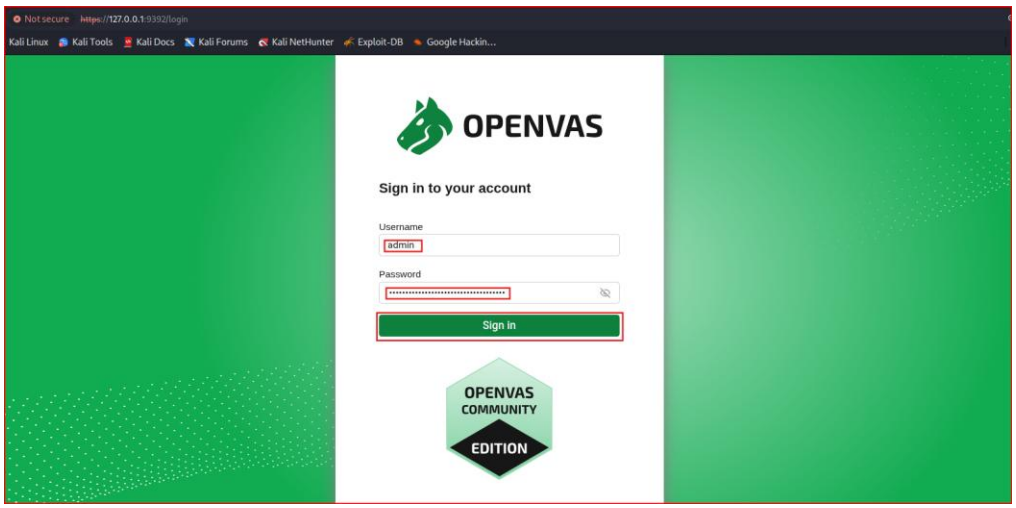
`sudo gvm-start`





Look for It seems like your GVM-xx installation is OK at the end of the check. If it reports a problem, it prints the fix, so follow that and rerun.

Open **https://127.0.0.1:9392** and accept the browser's self-signed certificate warning. Log in as admin.

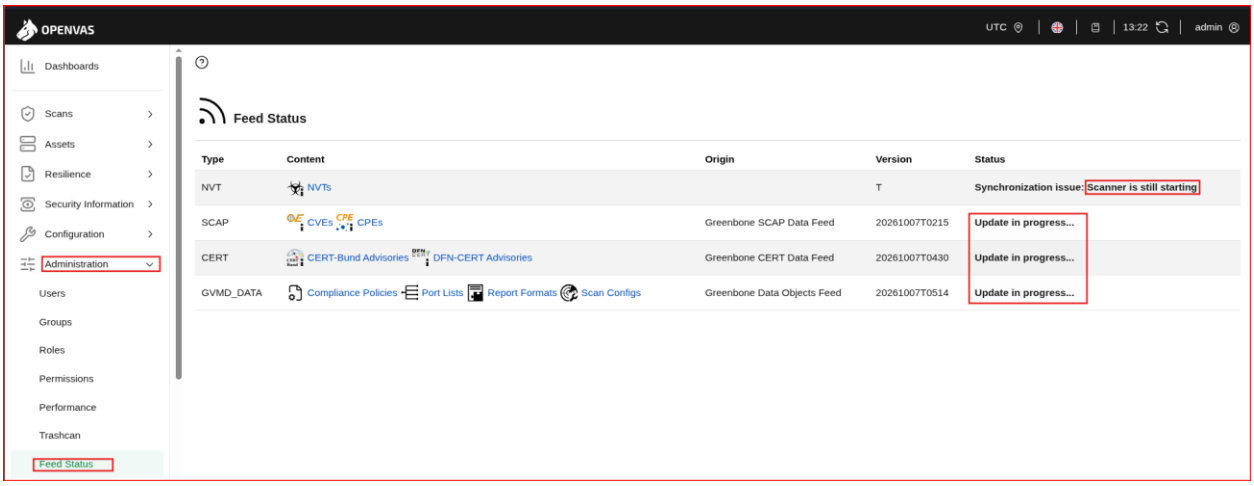


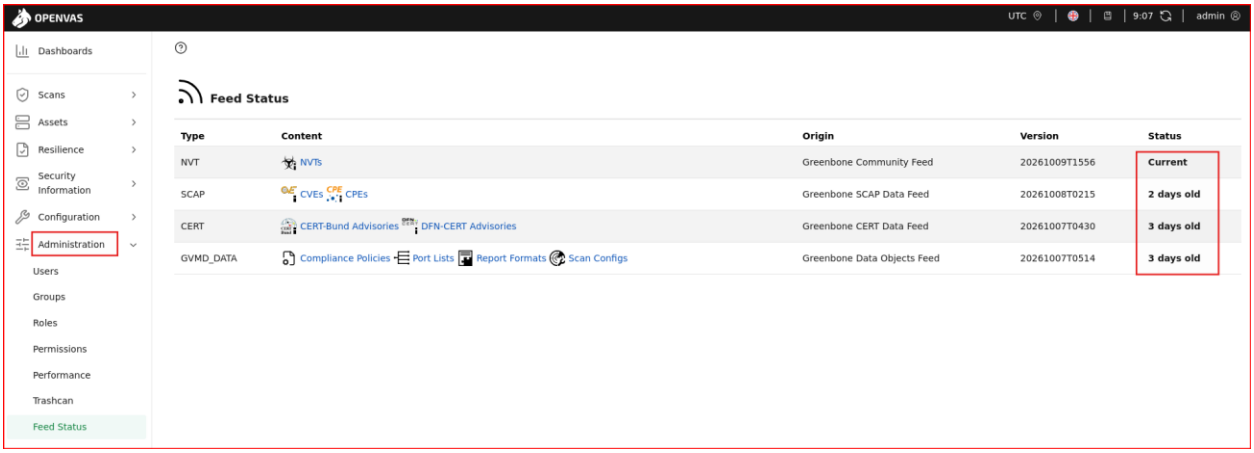
If you forgot the password, reset it:

```
sudo runuser -u _gvm -- gvmd --user=admin --new-password=admin123
```

Make sure the feeds are synced

Go to **Administration** → **Feed Status** and confirm NVT, SCAP, and CERT feeds all show a current status.





If the sync failed or is stale, run:

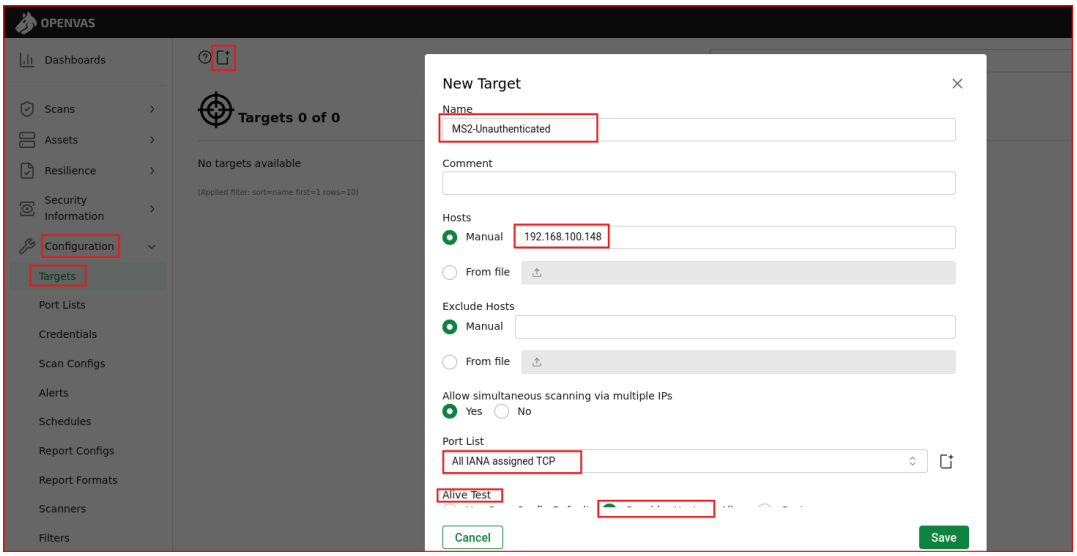
```
sudo -u _gvm greenbone-feed-sync
```

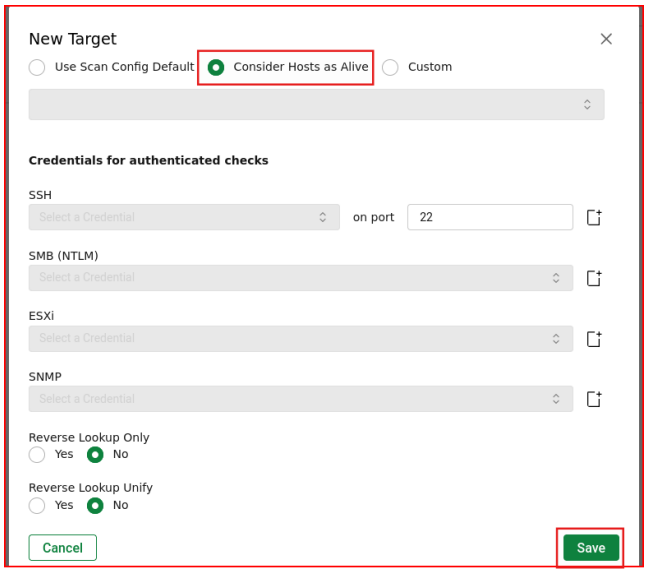
If that command isn't found on your version, sudo greenbone-feed-sync works on some Kali builds. It can take a long time on the first run, so let it finish.

Performing Scan-1

Create the target. Configuration → Targets → New:

- Name: MS2-Unauthenticated
- Host: your verified IP
- Port list: All IANA assigned TCP
- Alive test: Consider Hosts as Alive (the lab host is known to be up)

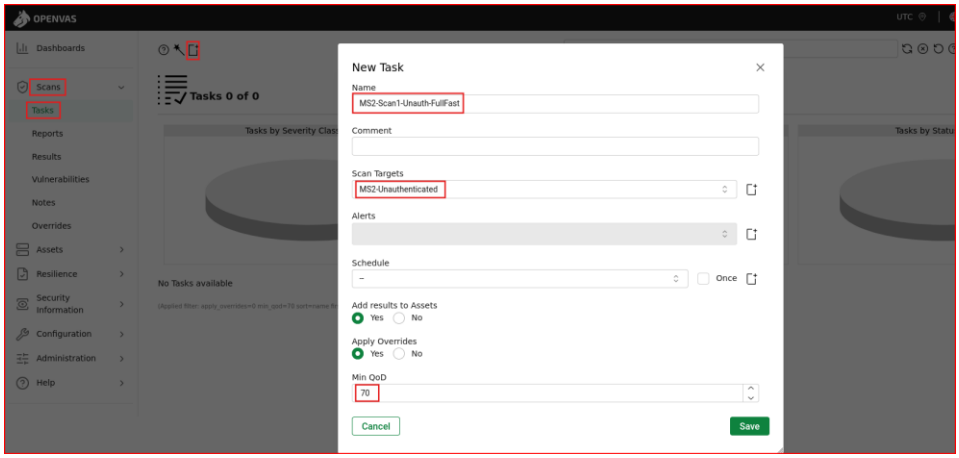


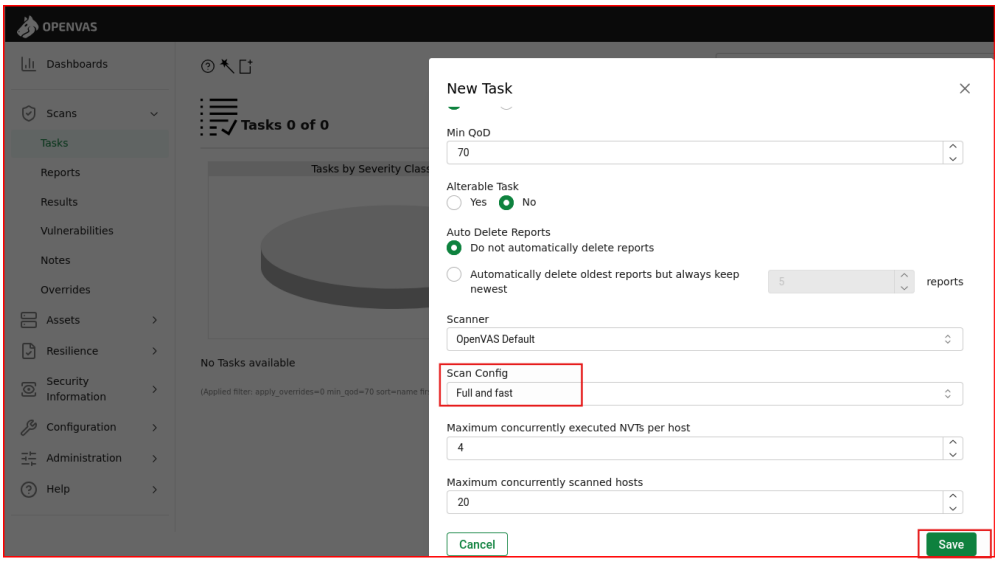




Create the task. Scans → Tasks → New:

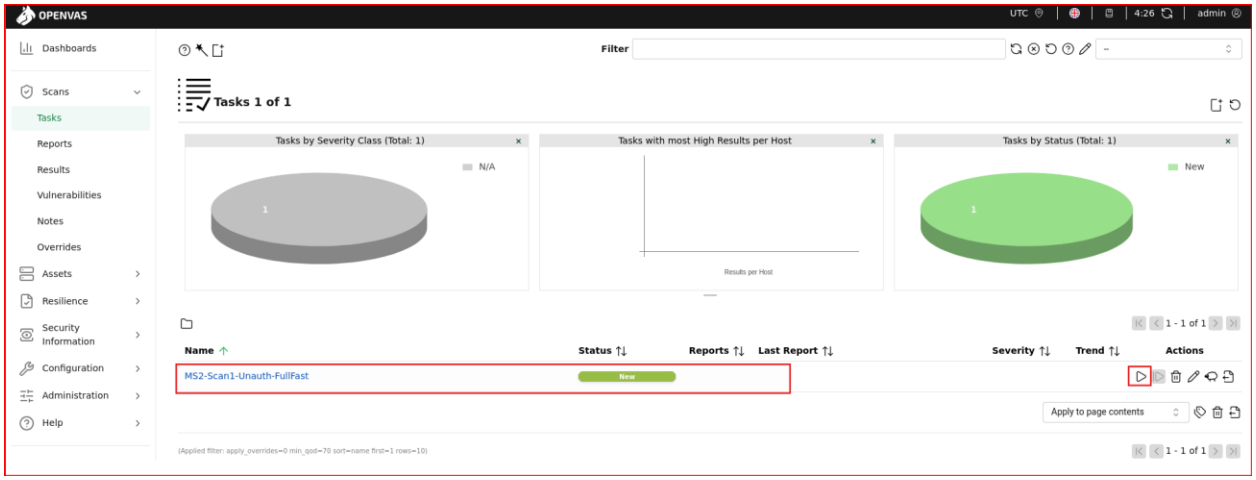
- Name: MS2-Scan1-Unauth-FullFast
- Scan Config: Full and fast
- Min QoD: 70%

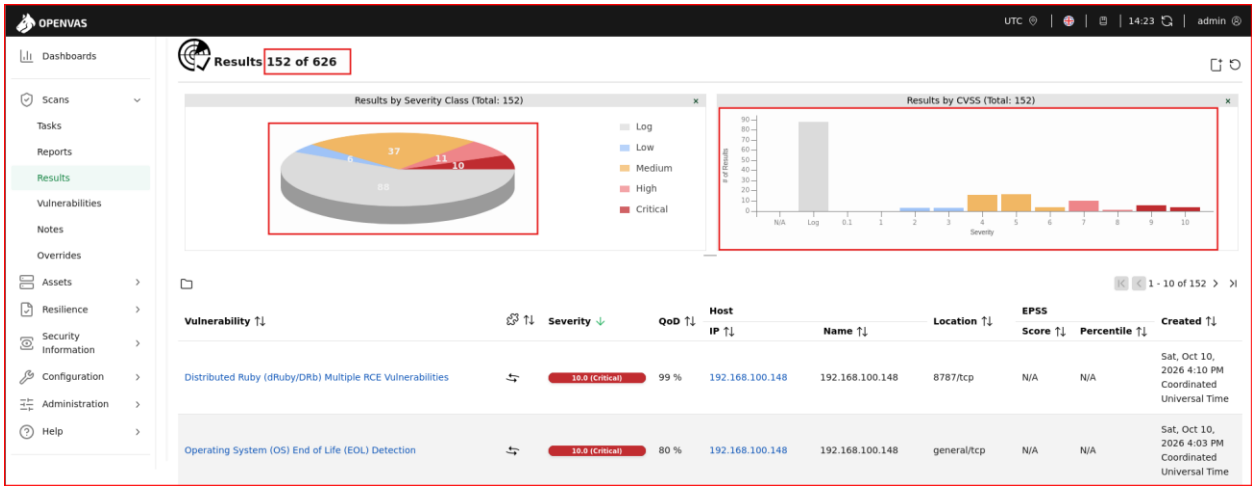


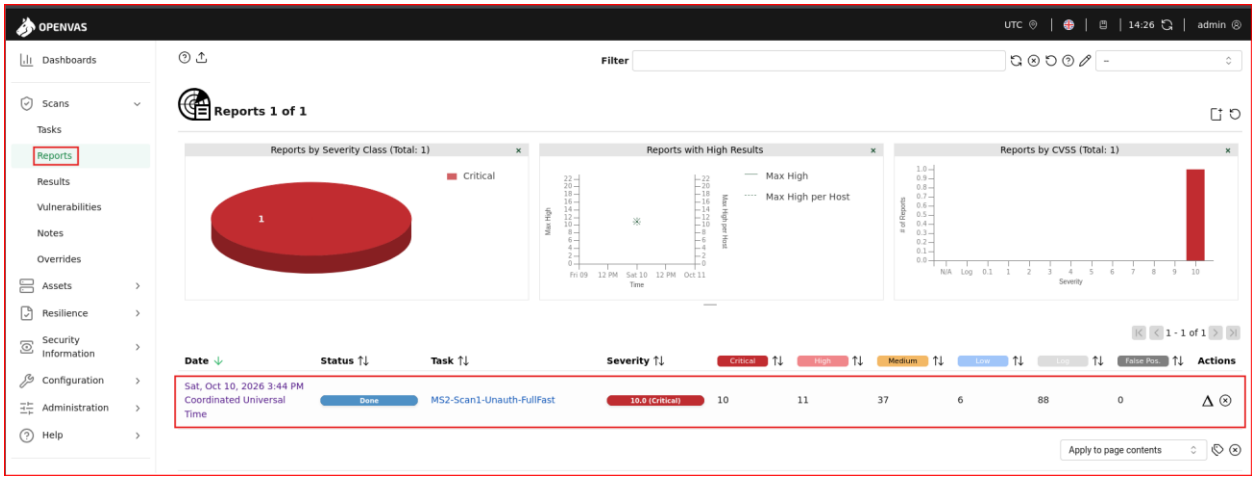


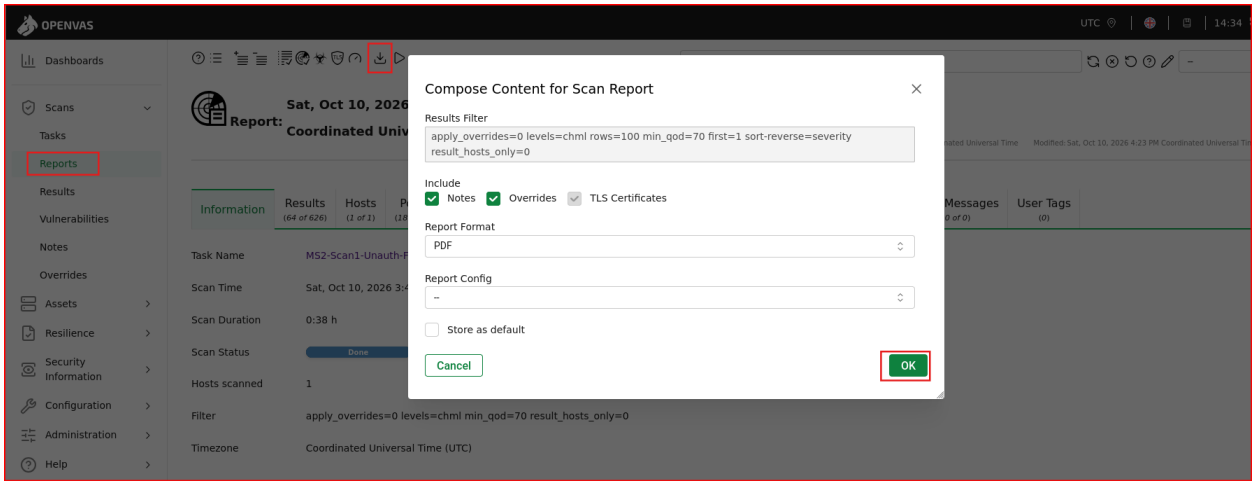
Running Scan-1

Run it, then record the start/end time, duration, and severity counts per class. Save the PDF and also an XML or CSV export (for counting and charts) into openvas/.

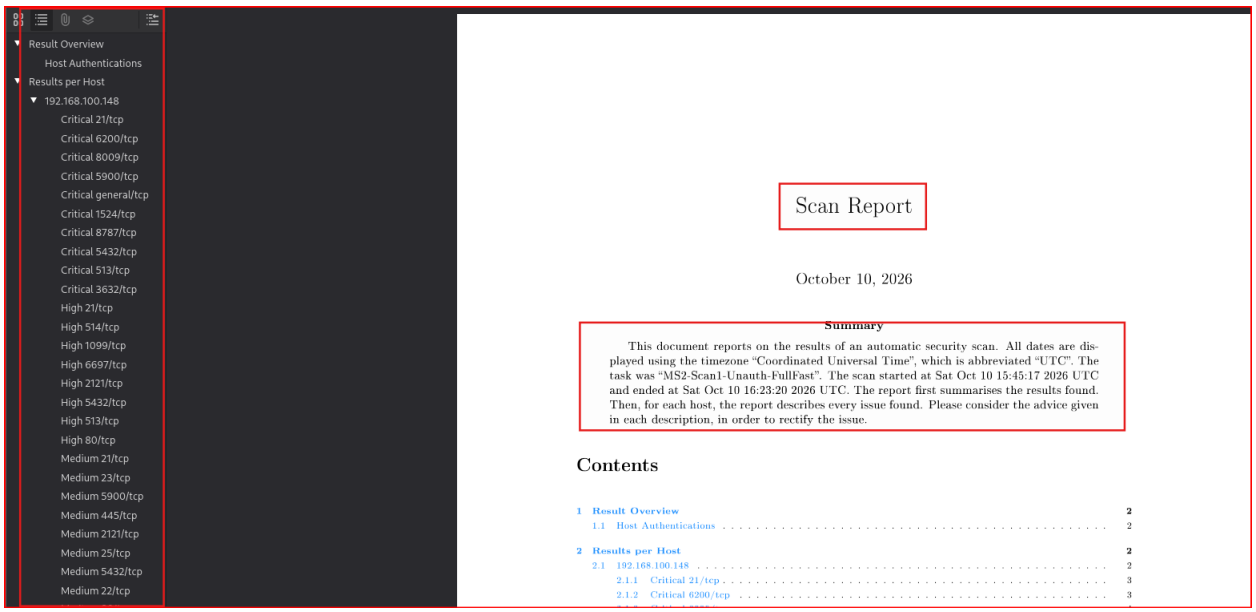








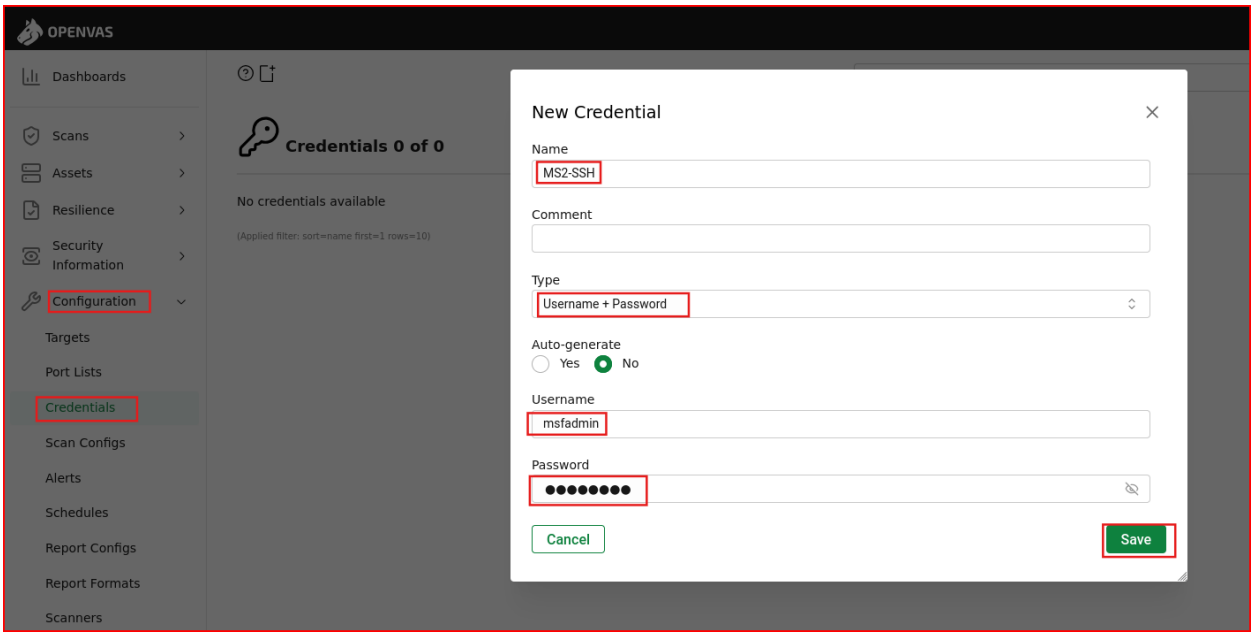
Report Generated

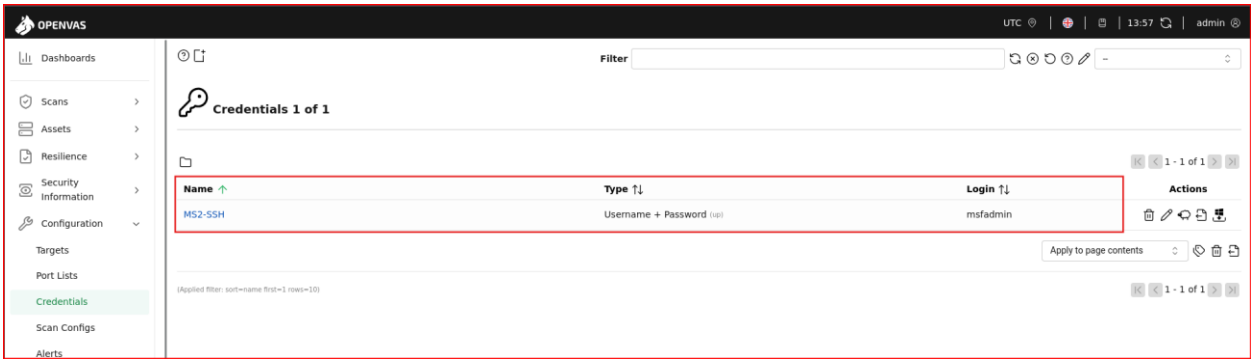


OpenVAS scan 2 (credentialed)

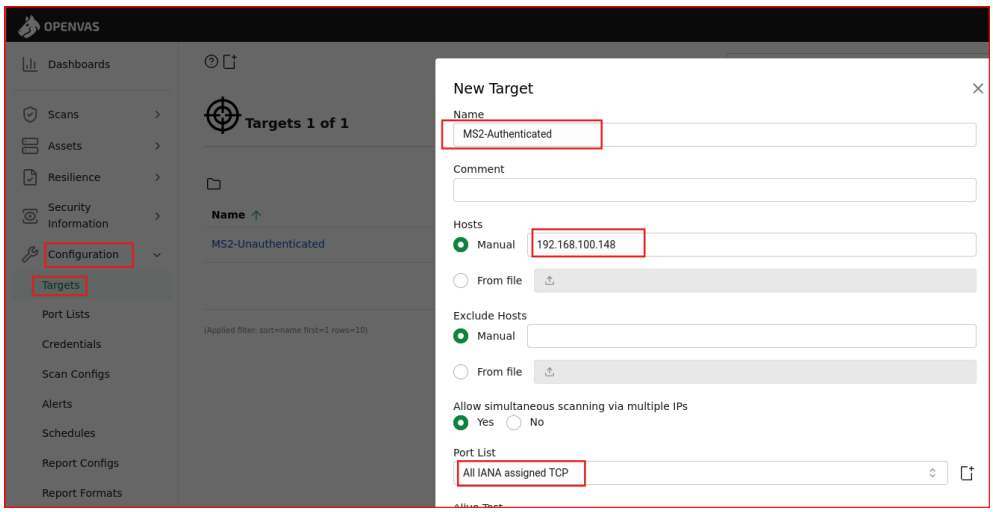
Create credentials. Configuration → Credentials → New:

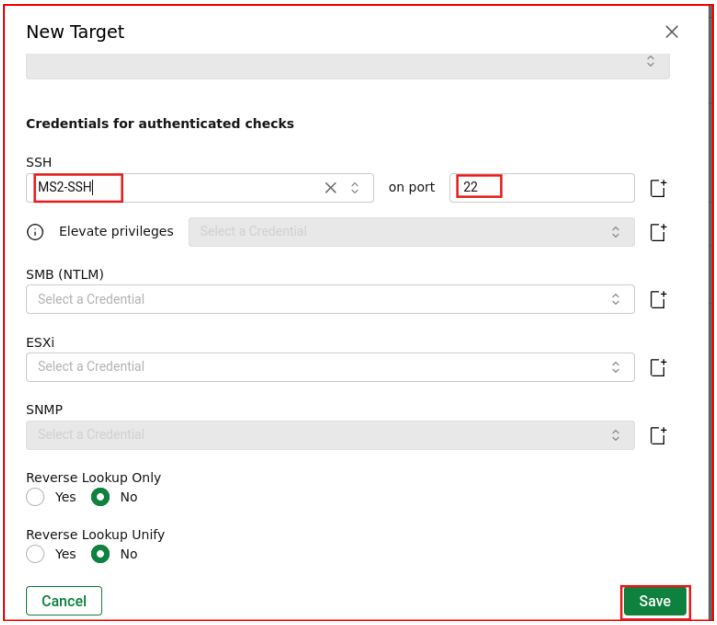
- Type: Username + Password
- Username/password: Metasploitable2's msfadmin / msfadmin
- Name: MS2-SSH

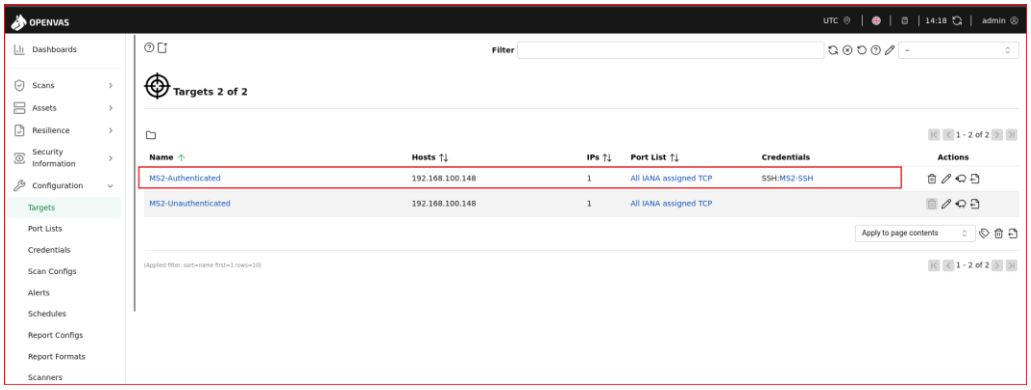




Create a second target named MS2-Authenticated, same IP, with **SSH credential** set to MS2-SSH on port 22.

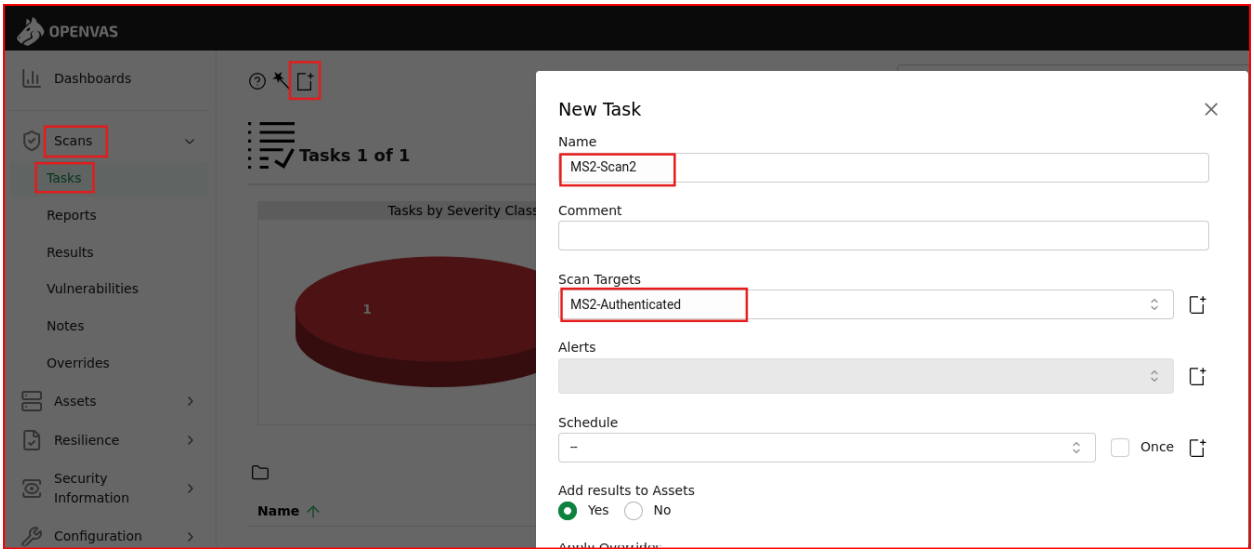


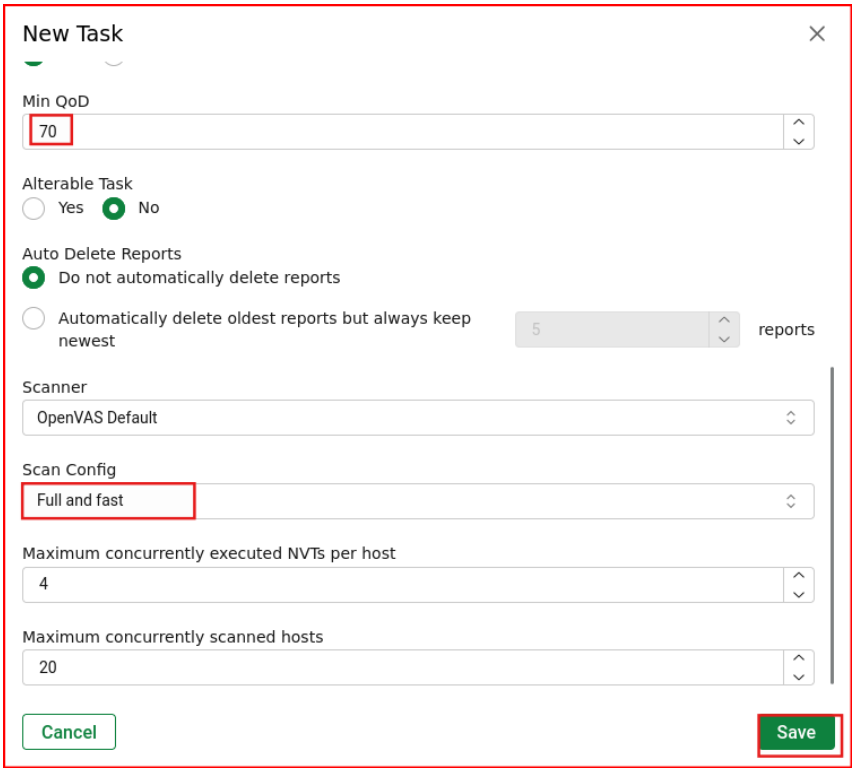




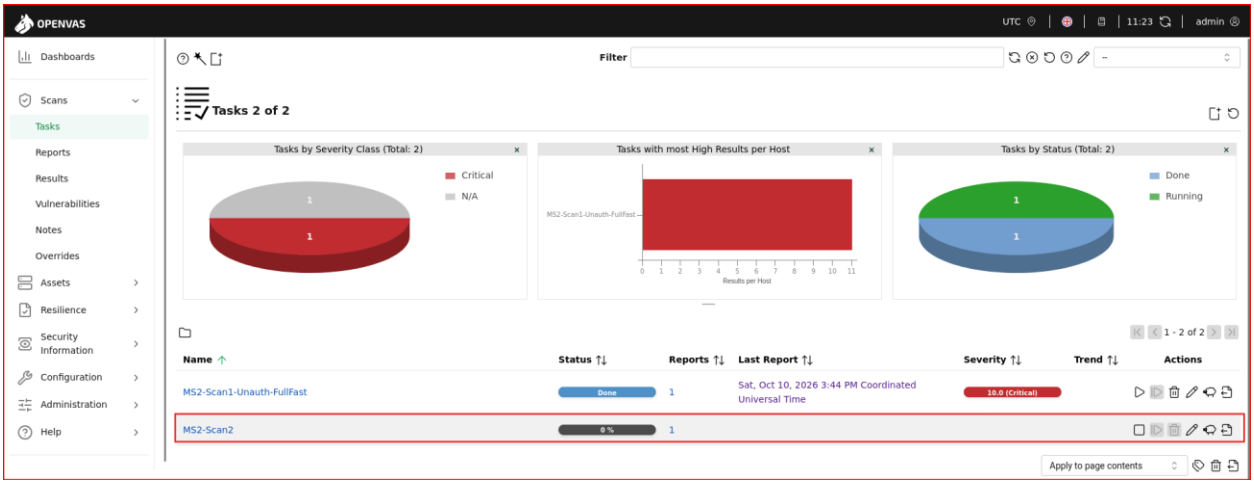
Creating a Second Task

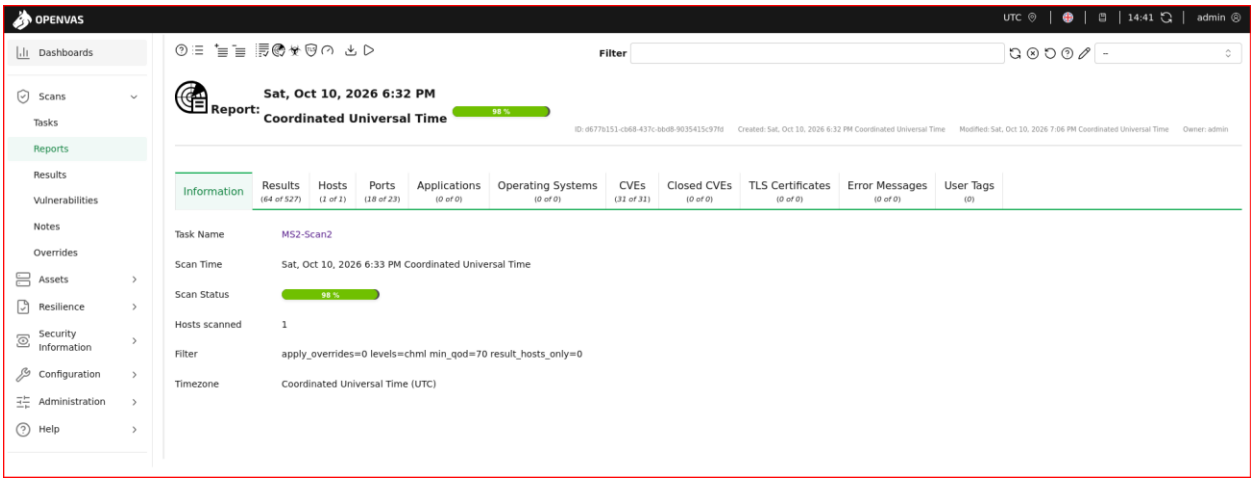
MS2-Scan2-Auth-FullFast. Run it and export PDF and XML/CSV.

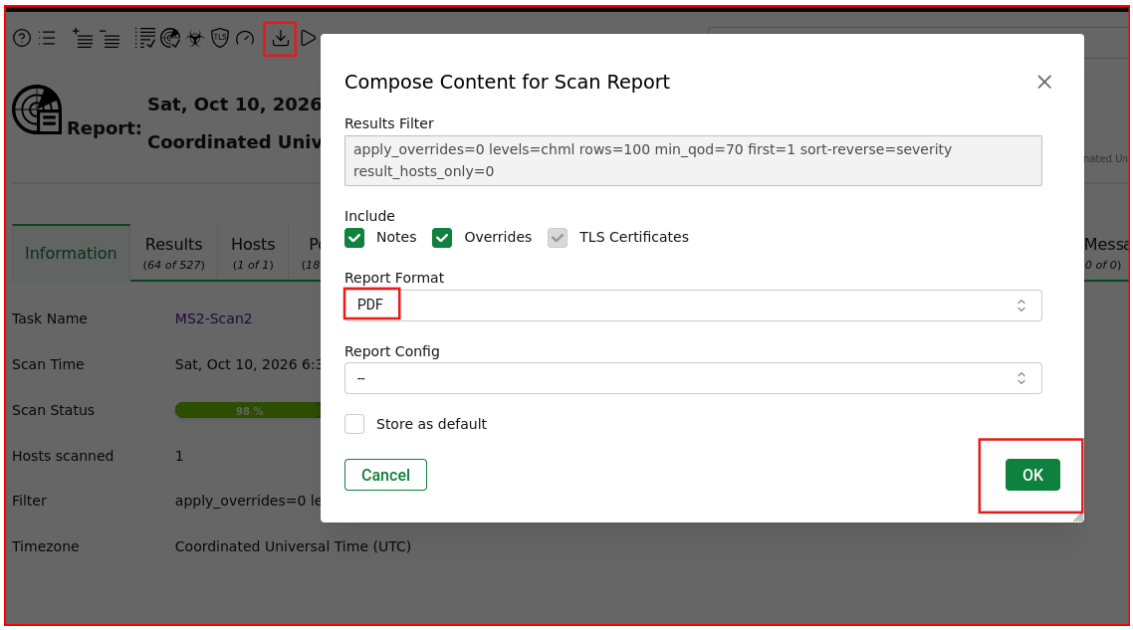




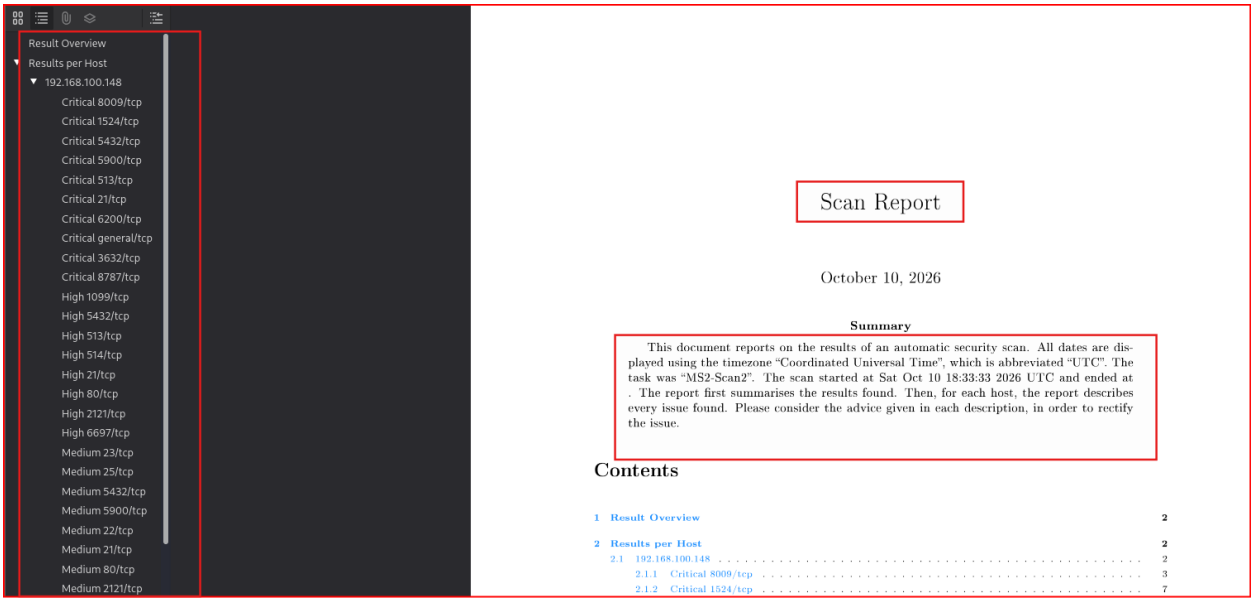
Running Scan-2







Report Generated



Analysis

Scan overview

Item	Scan 1 (Unauthenticated)	Scan 2 (Credentialed)
Task	MS2-Scan1-Unauth-FullFast	MS2-Scan2
Start / end (UTC)	15:45:17 / 16:23:20 (about 38 min)	18:33:33 / not recorded (exported at 98%)
Results before QoD ≥ 70 filter	626	527
Results shown	64	64
Critical / High / Medium / Low	10 / 11 / 37 / 6	10 / 11 / 37 / 6
Highest CVSS	10.0	10.0

The target, Metasploitable2 (192.168.100.148), is in critical condition under both scans. Every severity bucket is populated, and the OS itself is end-of-life.

Nmap vs. OpenVAS

Nmap found **30 open TCP ports** and 4 open UDP ports (53, 111, 137, 2049). It identified the exact software versions: vsftpd 2.3.4, OpenSSH 4.7p1, Apache 2.2.8, Samba 3.x, PostgreSQL 8.3.x, UnrealIRCd, DistCC, and Tomcat. The NSE vuln script confirmed the vsftpd backdoor and found CSRF issues on Tomcat (port 8180).

OpenVAS turned that inventory into prioritized, scored findings. It reported on **17 individual ports plus host-wide issues**, and it confirmed many flaws by actually exploiting them. Examples are the id command returning uid=0(root) on port 1524, the /WEB-INF/web.xml file read over AJP, and the PUT/DELETE upload test on /dav.

The two tools complement each other. Nmap is better for enumeration, and OpenVAS is better for validated vulnerability evidence.

Two observations:

- Port 6200 does not appear in the Nmap port list but is a Critical finding in OpenVAS. The vsftpd backdoor check triggered the backdoor shell, which opened the port during the scan.
- Some Nmap-visible services had no finding at QoD ≥ 70: MySQL (3306), NFS (2049), X11 (6000), DNS (53), rexec (512), and Tomcat on 8180. They are still part of the attack surface and should be checked manually.

Key findings by risk theme

a) Backdoored software (full compromise, no authentication needed)

- vsftpd 2.3.4 backdoor on 21/6200 (CVE-2011-2523)
- UnrealIRCd 3.2.8.1 backdoor on 6697 (CVE-2010-2075)
- Ingreslock bind shell on 1524, which returned a root shell (CVSS 10.0)

b) Remote code execution in exposed services

- DistCC on 3632 (CVE-2004-2687, ran as daemon)
- dRuby/DRb on 8787 (CVSS 10.0)
- Java RMI on 1099 (CVE-2011-3556)
- Samba usermap_script on 445 (CVE-2007-2447)
- Tomcat Ghostcat on 8009 (CVE-2020-1938)
- PHP-CGI argument injection on 80 (CVE-2012-1823)
- HTTP PUT/DELETE enabled in /dav, which allows arbitrary file upload

c) Default and weak credentials

- PostgreSQL postgres:postgres
- VNC password password
- FTP logins msfadmin, postgres, service, user, plus anonymous FTP
- rlogin and rsh allow root access with no password

d) Cleartext protocols: Telnet, FTP, rlogin, rsh, VNC, and HTTP login forms (DVWA, phpMyAdmin, TikiWiki) transmit credentials unencrypted.

e) Weak cryptography

- SSLv3, TLS 1.0, and RC4 are enabled.
- Export-grade ciphers are accepted (FREAK and Logjam).
- The OpenSSL CCS injection flaw is present.
- The certificate uses a 1024-bit RSA key and SHA-1, and it **expired on 2010-04-16**.
- SSH supports weak key exchange (DH group1/SHA-1), CBC and arcfour ciphers, ssh-dss host keys, and MD5/96-bit MACs.

f) Web application weaknesses: Mutillidae has local file inclusion and directory traversal (/etc/passwd was readable). phpinfo() pages are exposed, /doc is browsable, TRACE is enabled, and jQuery 1.3.2 and phpMyAdmin have XSS issues.

g) Information disclosure: SMTP VRFY, ICMP timestamps, and TCP timestamps.

h) Unsupported OS: Ubuntu 8.04 reached end of life on 2013-05-09, so it has received no security updates for about 13 years. This is the root cause behind many of the other findings, because patching in place is not possible.

A note on interpretation: some detections are named after products that are not really installed. “EasyPHP” and “awiki/QWikiwiki” were triggered by the exposed phpinfo.php and the vulnerable page= parameter in Mutillidae. The underlying weaknesses are real, but the product names are misleading. Also, the Samba finding is rated only CVSS 6.0, but on this host it yields command execution with high privileges, so it should be treated as Critical in practice.

Authenticated vs. unauthenticated comparison

Both scans reported **identical counts (10/11/37/6)** and the same 64 findings. The only differences are run-specific values such as the PUT test filename, the RMI callback port, and the TCP timestamps. The credentialed scan therefore **did not add any visible findings** at QoD ≥ 70, and it returned about 100 fewer raw results (527 vs. 626). A credentialed scan normally finds more, so this result is unusual. Possible explanations:

Greenbone's local security checks may not cover Ubuntu 8.04. Even a successful login would then add no package-based findings.

The main takeaway is that on this host the **unauthenticated attack surface is already severe enough** that credentials reveal little extra. An outside attacker with no login can already obtain root.

Remediation priorities

Priority	Action	Addresses
1	Disable or remove ingreslock, rlogin, rsh, rexec, telnet, distccd, dRuby, Java RMI, and AJP. Block them with a firewall.	Backdoors and unauthenticated RCE
2	Replace backdoored vsftpd and UnrealIRCd with verified packages.	Supply-chain backdoors
3	Change all default credentials (PostgreSQL, VNC, FTP, system accounts) and disable anonymous FTP.	Default credentials
4	Disable PUT/DELETE and TRACE. Remove phpinfo.php, restrict /doc, and remove or isolate Mutillidae, DVWA, and phpMyAdmin.	Web exposures
5	Upgrade or rebuild on a supported OS. This is the only real fix for the unpatched software.	EOL OS and outdated packages
6	Disable SSLv3/TLS 1.0 and export ciphers. Replace the certificate with a 2048-bit or larger SHA-256 certificate. Remove weak SSH algorithms.	Weak cryptography
7	Disable ICMP and TCP timestamps and the SMTP VRFY command.	Information disclosure

For the lab, Priorities 1 to 4 and 6 to 7 can be done on the existing VM. Priority 5 means rebuilding the VM. The Phase 7 re-scan should then confirm that the Critical and High counts drop sharply compared with the baseline.

Limitations

- Only results with QoD ≥ 70 are shown, so lower-confidence findings are excluded.
- Active checks changed the target during the scan (the vsftpd backdoor opened port 6200 and the PUT test created files in /dav).
- Scores are CVSS base scores and do not reflect this lab's context, in which the target is deliberately vulnerable and isolated.

Conclusion

Metasploitable2 is critically insecure. Several services give an attacker remote code execution or root access without authentication, and the operating system is unsupported. Nmap and OpenVAS complemented each other: Nmap supplied an accurate inventory of ports and versions, while OpenVAS supplied scored findings backed by active validation.

The main lesson is that an end-of-life system carrying known backdoors cannot be fixed by patching alone. The practical remedy is to remove the vulnerable services in priority order (backdoors and remote-access services first, then default credentials, web exposures, and weak cryptography) and rebuild on a supported platform. Scanner output also needs interpretation. Some findings were named after products that are not installed, and the Samba flaw was rated only CVSS 6.0 despite giving command execution.

The results have limits. Only findings with QoD ≥ 70 were included, active checks changed the target during scanning, and the credentialed scan was not verified to have logged in successfully. The next step is to apply the fixes and re-scan, so the drop in Critical and High findings can be measured against this baseline.